

# Cirque Corporation

## Access Control Policy

**Document ID:** IS-CIRQ-P-008-G

**Category:** IT Security Related

**Division:** Policy

**Type:** Global

**Version:** 1.1

**Effective Date:** 2025-07-01

**Review Date:** 2026-07-01

**Approved By:** Executive Committee

**Generated:** March 02, 2026

### 1. Purpose

The purpose of this policy is to define Cirque's requirements for controlling access to all information assets, systems, applications, networks, and physical facilities. This policy aims to protect Cirque's information from unauthorized access, modification, disclosure, or destruction, in accordance with ISO/IEC 27001:2022 Annex A.8.2. It ensures that access is granted based on the principle of least privilege and need-to-know.

**\*\*2. Scope\*\***

### 2. Scope

This policy applies to all Cirque personnel (employees, contractors, temporary staff), external users requiring access, and all Cirque information assets, IT systems, applications (e.g., Omnify, Cadence, GitLab, Asana, QuickBooks, Microsoft 365 services), networks, and physical facilities (e.g., US and Taipei offices).

### **\*\*3. Principles of Access Control\*\***

## **3. Principles of Access Control**

Cirque implements access controls based on the following principles:

- **\*\*Least Privilege:\*\*** Users shall be granted only the minimum access rights necessary to perform their legitimate job functions.
- **\*\*Need-to-Know:\*\*** Access to information and systems shall be granted only to individuals who require it to perform their assigned duties.
- **\*\*Segregation of Duties (SoD):\*\*** Conflicting duties and areas of responsibility shall be segregated to reduce the risk of fraud, error, or unauthorized access.
- **\*\*Accountability:\*\*** All access to information assets shall be logged and attributable to individual users.
- **\*\*Regular Review:\*\*** Access rights shall be regularly reviewed and updated.

### **\*\*4. User Access Management\*\***

## **4. User Access Management**

**\*\*4.1. User Registration and De-registration:\*\*** a. A formal process shall be in place for managing user accounts, covering their entire lifecycle from creation to de-activation/deletion. b. User accounts for computers and internal systems are primarily managed through **\*\*Active Directory\*\***. c. User accounts shall be created only upon receipt of formal authorization (e.g., from HR for new hires, from Department Managers for contractors). d. User accounts shall be promptly modified (e.g., role change) or de-activated/deleted upon termination of employment, contract, or change in job function, or if prolonged inactivity is detected.

**\*\*4.2. User Access Provisioning:\*\*** a. Access rights shall be formally provisioned based on role, job function, and approved requests. b. Generic or shared accounts are generally prohibited, and individual accountability must be maintained where exceptional use of shared accounts is approved. c. Access to highly sensitive systems or data (e.g., source code in GitLab, ASIC designs in Cadence, customer sales data in Omnify/QuickBooks) requires specific, documented authorization from the Asset Owner or IT Manager. d. **\*\*Access to all internal hosted tools (e.g., GitLab, Asana, QuickBooks, Omnify, Cadence) is restricted to employees only; no external collaborators are permitted.\*\*** e. **\*\*Guest access to SharePoint for specific documents may be granted on an as-needed basis, strictly controlled by the IT Manager or designated document owner.\*\***

**\*\*4.3. User Access Review:\*\*** a. Access rights shall be reviewed periodically (at least annually) or when a user's role changes. This review ensures that access remains consistent with job responsibilities and the principle of least privilege. b. The IT Manager, in collaboration with Department Managers and Asset Owners, is responsible for conducting these reviews, using reports from Active Directory, application logs, and other relevant systems.

**\*\*5. System and Application Access Control\*\***

## **5. System and Application Access Control**

**\*\*5.1. Authentication:\*\*** a. All users shall authenticate to systems and applications using unique credentials managed via **\*\*Active Directory** or individual application authentication where Active Directory integration is not feasible.\*\* b. Strong password policies (complexity, length, expiry) shall be enforced. c. Multi-Factor Authentication (MFA) shall be implemented for all remote access, privileged access, and access to

critical cloud services (e.g., Microsoft 365, GitLab).

**\*\*5.2. Privileged Access Management:\*\*** a. Privileged accounts (e.g., administrative accounts within Active Directory or specific applications) shall be strictly controlled and used only when absolutely necessary for system administration tasks. b. Access to privileged accounts shall be logged, monitored, and reviewed regularly. c. Where possible, dedicated privileged accounts, separate from standard user accounts, shall be used.

**\*\*5.3. Network Access Control:\*\*** a. Network access shall be controlled through firewalls, network segmentation, and secure network configurations. b. Wireless networks shall be secured with strong encryption (e.g., WPA2 Enterprise) and authentication. c. Remote access to Cirquel's internal networks shall only be permitted via a secure VPN connection from company-managed devices, with MFA enforced.

**\*\*5.4. Operating System and Application Access Control:\*\*** a. Operating systems and applications shall be configured to enforce access controls (e.g., user groups, permissions lists within Active Directory). b. Default passwords shall be changed, and unnecessary default accounts disabled or removed. c. Session timeouts shall be implemented to lock idle user sessions. d. Device management tools like **\*\*Intune\*\*** shall be used to enforce security configurations and access policies on endpoints.

**\*\*6. Physical Access Control\*\***

## **6. Physical Access Control**

**\*\*6.1. Secure Areas:\*\*** a. Access to physical locations containing sensitive information assets (e.g., server rooms, critical engineering labs, storage areas for physical documents) shall be restricted to authorized personnel only. b. Entry to the **\*\*US and Taipei offices\*\***

shall be controlled via the **Unifi Access system**. c. Visitors shall be controlled (e.g., sign-in, escorted by staff, temporary badges provided by Unifi Access or manually).

**6.2. Monitoring:** a. Access to secure areas shall be logged by the **Unifi Access system**. b. CCTV surveillance may be used in critical areas.

**7. Related Documents**

## **7. Related Documents**

- IS-CIRQ-PR-008-G: Access Control Procedure (To be drafted next)
- IS-CIRQ-P-007-G: Asset Management Policy
- IS-CIRQ-PR-007-G: Asset Classification and Handling Procedure
- IS-CIRQ-P-009-G: Acceptable Use Policy (Tentative future policy)
- User Access Request Form (maintained in ticketing system and approved by IT Manager)

**8. Policy Review**

## **8. Policy Review**

This policy will be reviewed at least annually, or sooner if significant changes occur to Cirquel's IT environment, organizational structure, or legal/regulatory requirements.